SPOTIFY'S DATA & AI GOVERNANCE PROJECT

2.1. *Data & AI Governance Policy* Document

> *Nicolas Pichon --- AIA RNCP 38777 / BC01 / Step 2-1 / v16 --- 2026/10/15.*

2.1.1. Objectifs

Ce document définit la *politique de gouvernance des données et de l'IA* applicable à l'ensemble des activités de Spotify [R2].

Les objectifs de la *gouvernance* des données sont : la conformité réglementaire, la qualité des données, l'usage responsable des modèles, l'efficacité opérationnelle. La *politique* de gouvernance sert les objectifs précédents en définissant les principes, en fixant les règles et en établissant les responsabilités de la gouvernance.

2.1.2. Périmètre

La gouvernance des données et de l'intelligence artificielle chez *Spotify* couvre les données suivantes :

- les données utilisateur (journaux d'activités, préférences, facturations),
- les métadonnées de contenu, les données d'engagement marketing,
- les données d'entrainement et les modèles d'apprentissage automatique utilisés en production.

La politique de gouvernance s'appuie directement sur le diagnostic de maturité [D1] : une maturité globalement de niveau 1 (gouvernance locale, réactive, dispersée) sur la majorité des dimensions de gouvernance, de qualité, de sécurité et de conformité, avec des points forts de niveau 2 (gouvernance globale en cours de développement) en usage décisionnel, littératie et analytique.

2.1.3. Principes

Les principes énumérés ci-dessous sont issus du référentiel [R4] et repris quasiment sans changements. Ils constituent le socle de la politique de gouvernance.

P1 - Responsabilité. Chaque actif de données et chaque modèle en production dispose d'un responsable identifié (*Data Owner*, *Data Steward*, *Model Owner*), selon la structure organisationnelle définie dans [D22].

P2 - Transparence. Les traitements des données personnelles sont documentés et communiqués aux utilisateurs de façon claire, via des mentions d'information et une gestion du consentement conformes aux réglementation *GDPR*/*CCPA*.

P3 - Sécurité des données. Les données sensibles (données personnelles, données de paiement) sont protégées par chiffrement, contrôle d'accès *par rôle* et protocoles *PCI-DSS*.

P4 - Qualité des données. Des règles de qualité mesurables (exactitude, complétude, fraîcheur) sont définies et auditées régulièrement, avec une attention particulière aux données alimentant le moteur de recommandation.

P5 - Conformité réglementaire. Les traitements de données sont conformes aux réglementations applicables (*GDPR*, *CCPA*, *PCI-DSS*, et réglementations locales - telles que le *PDPA* à Singapour). Un processus de veille est mis en place pour intégrer les évolutions légales.

P6 - Minimisation des données. Seules les données strictement nécessaires aux finalités métier sont collectées et conservées, réduisant l'exposition au risque en cas de violation.

P7 - Droits des utilisateurs. Les utilisateurs disposent de moyens effectifs pour accéder à, modifier, supprimer leurs données ou s'opposer à leur traitement, conformément aux droits GDPR et CCPA.

P8 - Éthique et gouvernance de l'IA. L'usage des modèles d'IA fait l'objet d'une gouvernance dédiée : traçabilité des données d'entraînement, détection des biais algorithmiques, explicabilité des systèmes de décision automatisée, responsabilisation et pilotage des processus de déploiement des modèles en production.

P9 - Amélioration continue. Le cadre de gouvernance est révisé périodiquement pour tenir compte de l'évolution de la réglementation, des technologies, et des besoins de l'entreprise, avec des cycles de mesure de maturité alignés sur la méthodologie du *DMAT* [R1].

2.1.4. Conformité réglementaire

La politique structure la conformité en reprenant cadre par cadre les exigences réglementaires [R5] :

- **GDPR**
  - Traitement licite, loyal et transparent des données,
  - Droits d'accès, de rectification et de suppression garantis aux utilisateurs,
  - Recueil d'un consentement explicite et éclairé préalable au traitement,
  - Notification des violations de données à l'autorité de contrôle sous 72 heures,
  - Nomination d'un *Data Protection Officer* chargé du pilotage de la conformité.
- **CCPA**
  - Transparence sur le mécanisme d'*opt-out* pour la vente de données personnelles (les utilisateurs sont informés que, par défaut, la société *peut* vendre leurs données personnelles, mais qu'ils peuvent choisir de refuser cette revente de principe),
  - Droit d'accès, de modification et de suppression sur demande,
  - Garantie de non-discrimination envers les utilisateurs qui exercent leurs droits.
- **PCI-DSS**
  - Sécurisation de l'infrastructure réseau,
  - Protection des données de cartes bancaires par chiffrement ;
  - Gestion des vulnérabilités ;
  - Contrôle d'accès strict aux données de paiement ;
  - Tests réguliers des dispositifs de sécurité ;
  - Politique de sécurité de l'information formalisée et diffusée.

Ce socle est complété par un processus de *cartographie réglementaire* marché par marché (*PDPA* pour Singapour, équivalents locaux pour les autres marchés), piloté par l'équipe *Legal Team* en lien avec *DPO* [R2].

2.1.5. Gouvernance des données et des modèles d'IA

Spotify dispose de capacités analytiques avancées en production (moteur de recommandation, personnalisation temps réel), mais la gouvernance de ces systèmes reste à construire [R2]. La politique de gouvernance de ce document introduit les exigences spécifiques suivantes (traçabilité, détection, responsabilité, explicabilité) :

1. **Traçabilité des données d'entraînement**
   - Chaque jeu de données utilisé pour entraîner un modèle de production doit être *documenté* (source, période, transformations appliquées, lineage) et *versionné*.
2. **Détection et réduction des biais**
   - Les modèles qui impactent fortement l'utilisateur font l'objet d'une *évaluation périodique* des biais algorithmiques et de leurs effets sur la représentativité des contenus proposés.
3. **Responsabilité et déploiement des modèles**
   - Chaque modèle en production est sous la responsabilité d'un *Model Owner* bien identifié.
   - Celui-ci collabore avec le *Model Risk Manager* et, éventuellement, avec le *Data Governance Committee* pour approuver le déploiement en production d'une version donnée d'un modèle. Le circuit d'approbation du déploiement dépend du *niveau d'impact* du modèle sur les utilisateurs.
4. **Explicabilité**
   - Les décisions automatisées ayant un impact significatif sur l'expérience utilisateur doivent pouvoir être expliquées de manière intelligible, en cohérence avec les exigences émergentes de gouvernance de l'IA.

Niveaux d'impact

La mesure de l'impact d'un modèle sur les utilisateurs dépend des critères suivants : 1) la *portée* du modèle (nombre d'utilisateurs exposés au modèle), 2) sa *réversibilité*, 3) son *exposition réglementaire* (en particulier, aux art. 9 et 22 du GDPR), 4) sa *priorité fonctionnelle*.

Ces critères sont combinés pour déterminer le *niveau d'impact* du modèle : *fort*, *modéré*, ou *faible*, le niveau le plus faible étant affecté par défaut. Chaque niveau d'impact détermine à son tour un *circuit d'approbation de déploiement* spécifique (impliquant a minima le *Model Owner* du modèle)
et applicable à chaque version du modèle sélectionnée pour un déploiement en production.

2.1.6. Rôles et responsabilités

La mise en œuvre de cette politique repose sur les rôles pré-définis dans le modèle [R6]

- *Data Governance Committee*, *Chief Data Officer*, *Data Protection Officer*, *Data Steward*.

Ils sont complétés par les rôles déjà introduits dans [D1] :

- Gouvernance Data : *Data Owner* et *Data Custodian* (complètent la chaîne *CDO* + *DO*),
- Gouvernance IA : *Model Owner* et *Model Risk Manager* (introduits en §2.1.5).

Les rôles métiers introduits par le *business case* [R2] (*Head of Engineering*, *Marketing Director*, *Product Managers*, *Content Managers*(*)) sont intégrés comme parties prenantes opérationnelles de la gouvernance, chacun étant responsable de l'application de la politique dans le périmètre de son métier et *Data Owner* de ses actifs de données.

> (*) *Content Manager* n'est pas un rôle explicitement défini dans [R2]. Il est introduit par [D22] pour couvrir la responsabilisation des données dans le service *Content Curation*, en calquant le modèle des *Product Managers*.

La structure détaillée de l'organigramme, ainsi que les rattachements et les interactions entre rôles, font l'objet du document [D22].

2.1.7. Pilotage et amélioration continue

L'efficacité de cette politique est mesurée par des revues de maturité périodiques reprenant les critères d'évaluation établis par le document *DMAT* [R1]. L'objectif *à moyen terme* est de faire progresser les dimensions actuellement en niveau 1 (gouvernance locale, réactive, dispersée) vers un niveau 3 (bien définie et globale).

Références

Livrables

- [D1] *Data Maturity Assessment Report*
- [D22] *Organizational Chart*

Annexes

- [D21-Annexes] *Data Governance Policy Document's Annexes*

Ressources

- [R1] Australian Government Data Maturity Assessment Tool (2026)
- [R2] Spotify Business Case
- [R4] Governance Principles Guide
- [R5] Compliance Checklist
- [R6] Data Governance Roles Template

Documents applicables

- [A1] **[GDPR]** *General Data Protection Regulation* - Règlement (UE) 2016/679, 27 avril 2016. JO L 119, 4.5.2016.
- [A2] **[CCPA]** *California Consumer Privacy Act of 2018*, Cal. Civ. Code § 1798.100, amendé / CPRA (Prop. 24, 2020).
- [A3] **[PDPA]** *Personal Data Protection Act 2012* (No. 26 of 2012), Singapour, amendé en 2020.
- [A4] **[PCI-DSS]** *Payment Card Industry Data Security Standard (PCI DSS)*, v4.0.1, PCI Security Standards Council, juin 2024.